

Section 06

Industrial Security (Master)



Section 06 – Threat Intelligence for OT

Threat Intelligence for OT

Lecture Notes

Department of Computer Science

- 1 What is OT Threat Intel?
- 2 Sources
- 3 Frameworks
- 4 Operational Use
- 5 Programme Building

By the end of this section you will be able to

- Distinguish strategic, operational and tactical threat intelligence.
- Identify the small set of OT-relevant intel sources and their biases.
- Map adversary techniques to defenders' detections using ATT&CK for ICS.
- Run an intel-driven hunt in a real (lab) network.
- Avoid the common pitfalls of intel programmes that produce reports nobody reads.

1

What is OT Threat Intel?

Section 06 – Threat Intelligence for OT

Strategic – board-level: who targets us, why, how the landscape shifts

Operational – which campaigns are active, against which sectors

Tactical – IOCs, ATT&CK techniques, behavioural patterns

All three matter

A SOC that only consumes IOCs misses why the adversary is here in the first place. A board that only reads strategic reports misses the live campaigns this week.

Source: Bianco, D., The Pyramid of Pain, 2013 | Cyber Threat Intelligence Maturity Model (Sergio Caltagirone et al.).

Sandworm (RU/GRU) – Ukraine grid 2015/16, NotPetya 2017, Industroyer2

Volt Typhoon (PRC) – living-off-the-land in US critical infrastructure

CHERNOVITE (?) – PIPEDREAM toolkit, multi-vendor

CyberAv3ngers (IR/IRGC-affiliated) – Unitronics PLC defacements

Predatory Sparrow (?) – Iran steel mill 2022, Khuzestan railway

Source: Dragos Year in Review reports 2020–2024 | CISA advisories | Mandiant M-Trends.

2

Sources

Section 06 – Threat Intelligence for OT

Open CISA, vendor PSIRTs

Sector ISACs E-ISAC, WaterISAC, Auto-ISAC

Commercial Dragos, Mandiant, Forescout

Government BSI, NCSC, CCCS

Honeypots Conpot, Snare, sectoral

Underground criminal forums (with care)

Source: Various; quality and timeliness varies sharply – triangulate.

- Vendor PSIRTs under-disclose – exploits exist for years before CVE.
- Sector ISACs over-rotate to flagship members.
- Commercial intel companies push their products in the reports.
- Government attribution is selective and political.
- Underground forum chatter is partly noise and partly disinformation.

Caution

Treat any single source as a hypothesis. Confirm a campaign with at least two independent sources before acting on its scope.

Source: Threat-intel methodology: Caltagirone, S. et al., *Diamond Model*, 2013.

3

Frameworks

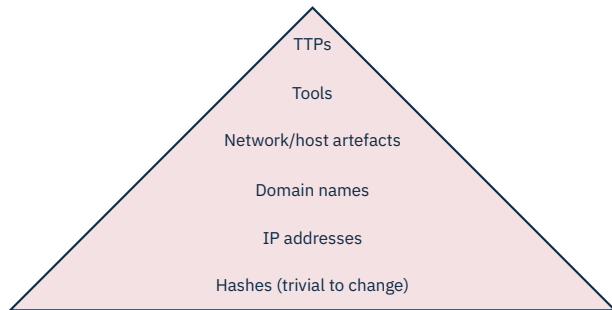
Section 06 – Threat Intelligence for OT



Use it for both directions

Adversary side: which techniques did campaign X use? Defender side: what do I detect today, and where are my gaps?

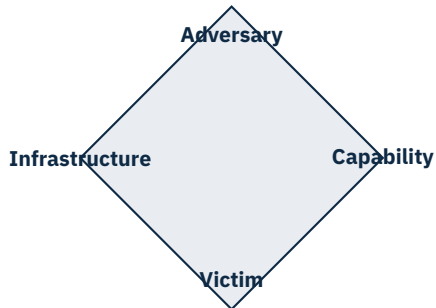
Source: MITRE, ATT&CK for ICS, <https://attack.mitre.org/matrices/ics/>.



Detect higher = hurt the adversary more

A signature on a hash dies in hours. Detection on a TTP forces the adversary to rebuild their playbook.

Source: Bianco, D., "The Pyramid of Pain", 2013.



Asking the right four questions

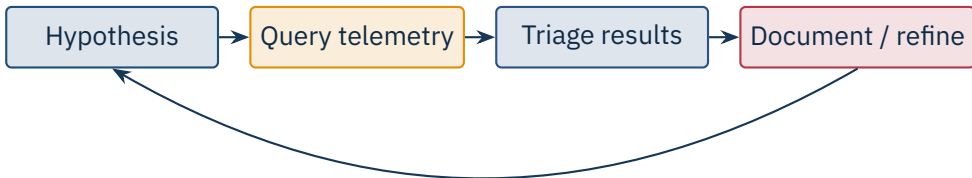
Who, what, on what, against whom. Filling all four corners gives you a hypothesis that survives the next data point.

Source: Caltagirone, S., Pendergast, A., Betz, C., The Diamond Model of Intrusion Analysis, 2013.

4

Operational Use

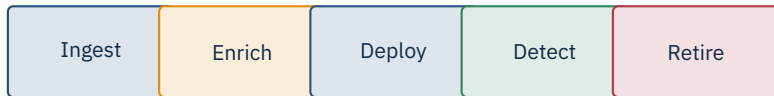
Section 06 – Threat Intelligence for OT



Example hypothesis

“Volt Typhoon uses living-off-the-land via wmic and netsh. Do we see scripted wmic from non-admin hosts in the last 30 days?”

Source: SANS Threat Hunting Maturity Model; Sqrrl/Splunk hunting playbooks.



Half-life

Network-side IOCs (IP, domain) decay in days. Host-side IOCs (file hash) decay in weeks. Behavioural rules persist for years.

- **STIX 2.1:** structured representation of threat intel.
- **TAXII 2.1:** transport API for sharing STIX over HTTPS.
- Wide vendor support; many ISACs deliver this way.
- Caveat: huge volume of low-signal indicators; filter aggressively.

Source: OASIS STIX 2.1 and TAXII 2.1 specifications, 2021.

5

Programme Building

Section 06 – Threat Intelligence for OT

Collection plan tied to the asset inventory

Tagging schema (sector, vendor, geography, criticality)

Hypothesis backlog from operational reading

Hunt cadence (weekly, monthly) and tracking

Feedback loop into SOC detections

- “Intel” that nobody reads (no consumer, no follow-up).
- IOCs deployed without context, generating alert fatigue.
- Detection improvements that never make it back to the platform.
- Single-source dependence (one vendor feed).
- Confusing CTI with marketing reports.

Caution

A CTI team without a tight feedback loop into detection engineering is decoration. Measure the time from *intel published* to *rule deployed*.



Reciprocity

You get what you give. ISACs work because members share, even when it is uncomfortable. Have an internal pre-approval list of what you can share without delay.

★ Key Takeaway: OT threat intelligence

- Three layers (strategic, operational, tactical) – a programme delivers all three.
- Six source families with known biases – triangulate, do not trust one.
- ATT&CK for ICS, Diamond Model, Pyramid of Pain are the operating frameworks.
- Hunt with hypotheses, not haystacks; feed results back to the SOC.
- Measure time from intel publication to deployed detection.

- Caltagirone, S., Pendergast, A., Betz, C. *The Diamond Model of Intrusion Analysis*, 2013.
- Bianco, D. “The Pyramid of Pain” blog post and presentations, 2013–2014.
- MITRE. *ATT&CK for ICS*, <https://attack.mitre.org/matrices/ics/>.
- Dragos. *Year in Review* reports 2020–2024.
- Mandiant. *M-Trends* annual reports.
- Microsoft Threat Intelligence. Volt Typhoon and related write-ups, 2023.
- CISA. ICS Advisories, BAS templates and IR resources.
- E-ISAC, WaterISAC, Auto-ISAC. Sector ISAC public summaries.
- BSI. *Lagebericht der IT-Sicherheit in Deutschland*, annual.
- NCSC-UK. ICS guidance and threat reports.
- OASIS. *STIX 2.1* and *TAXII 2.1* specifications, 2021.
- SANS Institute. *Threat Hunting Maturity Model* and related curriculum.

End of Section 06



Threat Intelligence for OT

Questions and discussion